

09-email-ciso-an-legal.eml

Von	ciso@lahnwerke.de
An	legal@lahnwerke.de
Datum	Tue, 26 May 2026 07:42:00 +0000
Betreff	Freigabe Slack / NIS2 / AirTags - brauche belastbare Linie

Guten Morgen,

der Vorstand will am Freitag entscheiden. Ich möchte nicht nur die üblichen Zertifikate zeigen, sondern eine echte Linie: NIS-2/BSIG, BSI-Grundschutz, Slack, AirTags, MDM, Java-Zertifikate und Incident-Meldeweg. Bitte auch aufnehmen, wo wir noch keine Nachweise haben.

Viele Grüße

Marlene

10-email-einkauf-supplier-remote.eml

Von	service@frankenturm-automation.de
An	einkauf@lahnwerke.de
Datum	Sat, 23 May 2026 14:06:00 +0000
Betreff	Dauerhafter VPN-Tunnel für Pressenwartung

Hallo,

für die neue Pressenlinie benötigen wir dauerhaft offenen VPN-Zugang aus unserem Servicecenter. Unser Standardvertrag sieht keine Session-Aufzeichnung vor. Ohne Zugriff verlieren Sie die Reaktionszeit im SLA.

Gruß

K. Rehbaum

15-betriebsrat-mdm-airtags.eml

Von	br@lahnwerke.de
An	vorstand@lahnwerke.de
Datum	Sun, 24 May 2026 16:22:00 +0000
Betreff	MDM, AirTags und neue Logging-Regeln

Sehr geehrte Damen und Herren,

wir verlangen Beteiligung vor Einführung weiterer MDM-, Tracking- und Loggingmaßnahmen. Uns liegt eine Liste von acht Fahrzeugen mit AirTags vor. Bitte stoppen Sie den Rollout bis zur Klärung der Zwecke, Zugriffsrechte und Löschrufen.

Betriebsrat

08-asset-inventar-auszug.csv

Asset	Typ	Owner	Kritikalität	Nachweis
SAP S4	ERP	IT Betrieb	hoch	CMDB
LKW AirTags	Tracker	Logistik	mittel	nur Excel
Code Signing CA	PKI	Engineering	hoch	unvollständig
Slack	SaaS	IT Collaboration	hoch	Security Memo

19-lieferanten-questionnaire.csv

Frage	Antwort Lieferant	Nachweis	Bewertung
MFA Fernwartung	ja	Screenshot Admin Portal	gelb
Session Recording	nein	Standardvertrag	rot
Incidentmeldung 24h	unklar	SLA	rot
Subunternehmer	Polen/Indien	Liste	gelb

22-anlagenindex.csv

Datei	Dokumenttyp	Wichtigkeit	Bemerkung
02-zeitstrahl-und-fristen.docx	DOCX	hoch	Ereignislinie mit technischen Quellen und Wiedervorlagen
03-prueffragen-fuer-erstgespraeche.docx	DOCX	hoch	Technisch und rechtlich strukturierter Gesprächsleitfaden
04-vorstandsvorlage-cyber-roadmap.docx	DOCX	hoch	Entwurf Vorstandsvorlage zur Cyber-Roadmap
05-cyber-risk-register.xlsx	XLSX	hoch	Risikoregister mit Maßnahmen, Ownern und Fristen
06-nis2-betroffenheitsvermerk.pdf	PDF	hoch	Vermerk zur vorläufigen NIS-2-/BSIG-Betroffenheit
07-slack-cloud-security-memo.pdf	PDF	hoch	Cloud-/SaaS-Prüfung Slack-Rollout
08-asset-inventar-auszug.csv	CSV	mittel	Asset-Inventar mit Lücken
09-email-ciso-an-legal.eml	EML	hoch	CISO fragt Legal nach Leitungsvorlage
10-email-einkauf-supplier-remote.eml	EML	mittel	Lieferant bittet um dauerhafte Fernwartung
11-backup-restore-protokoll.pdf	PDF	mittel	Restore-Test mit erkennbaren Lücken
12-whatsapp-it-legal.jpg	JPG	mittel	Chat-Screenshot IT/Legal mit operativer Dringlichkeit
13-screenshot-siem-alerts.jpg	JPG	mittel	SIEM-/SOC-Screenshot als Bilddatei
14-policy-entwurf-screenshots-und-chat.docx	DOCX	mittel	Policy-Entwurf Screenshots und Chat
15-betriebsrat-mdm-airtags.eml	EML	mittel	Betriebsrat verlangt Beteiligung
16-krisenstabs-runbook-auszug.docx	DOCX	hoch	Runbook-Auszug Krisenstab
17-cloud-provider-c5-luecken.pdf	PDF	mittel	Cloud-Provider-Prüfung C5/Region/Exit
18-java-pki-zertifikatsnotiz.docx	DOCX	hoch	Notiz zu Java-Code-Signing und PKI
19-lieferanten-questionnaire.csv	CSV	mittel	Supplier-Security-Fragebogen
20-board-briefing-draft.pdf	PDF	mittel	Board-Briefing als Arbeitsstand
21-offene-punkte-und-lueckenliste.docx	DOCX	mittel	Offene Punkte und Lückenliste
22-anlagenindex.csv	CSV	mittel	Anlagenindex

Datei	Dokumenttyp	Wichtigkeit	Bemerkung
23-entscheidungsvorlage-kurzfassung.docx	DOCX	hoch	Vorstandsvorlage mit konkreten Beschlussfeldern
24-arbeitsstand-fuer-besprechung.pdf	PDF	hoch	Arbeitskonferenz mit Quellen- und Maßnahmenstand

25-vpn-zugriffslog-frankenturm-roh.csv

zeitpunkt

2026-04-14 09:12

konto

svc-frankenturm

quelle_ip

185.44.72.19

ziel_system

Pressenlinie P2 HMI

dauer_min

38

ticketnummer

WART-2026-0412

bemerkung

geplante Wartung laut Auftrag

zeitpunkt

2026-04-29 22:47

konto

svc-frankenturm

quelle_ip

185.44.72.23

ziel_system

Pressenlinie P2 SPS

dauer_min

112

bemerkung

kein Ticket auffindbar

zeitpunkt

2026-05-07 03:18

konto

svc-frankenturm

quelle_ip

185.44.72.23

ziel_system

Pressenlinie P2 SPS

dauer_min

74

bemerkung

Login außerhalb Servicefenster, Anlass ungeklärt

zeitpunkt

2026-05-07 03:19

konto

svc-frankenturm

quelle_ip

185.44.72.23

ziel_system

Dateiablage ENG-SHARE

dauer_min

9

bemerkung

Zugriff auf Ordner Konstruktion, laut Berechtigungskonzept nicht vorgesehen

zeitpunkt

2026-05-12 10:05

konto

svc-frankenturm

quelle_ip

185.44.72.19

ziel_system

Pressenlinie P2 HMI

dauer_min

41

ticketnummer

WART-2026-0503

bemerkung

Firmwareupdate dokumentiert

zeitpunkt

2026-05-23 16:44

konto

svc-frankenturm

quelle_ip

185.44.72.23

ziel_system

Pressenlinie P2 SPS

dauer_min

3

bemerkung

Verbindungsaufbau, nach MFA-Umstellung abgebrochen

zeitpunkt

2026-05-30 08:02

konto

svc-frankenturm

quelle_ip

185.44.72.19

ziel_system

Pressenlinie P2 HMI

dauer_min

27

ticketnummer

WART-2026-0561

bemerkung

Abnahme mit Begleitung IT-Betrieb

Tabellenblatt: Risiken**ID**

R-01

Risiko

Ransomware verschlüsselt ERP und Produktionsplanung

Asset

SAP + Fileserver

Impact

sehr hoch

Kontrolle

Immutable Backup + Restore-Test

Owner

CISO

Frist

2026-06-21

Statusgelb

ID

R-02

Risiko

Slack-Screenshots enthalten Kundendaten und VPN-Token

Asset

Slack Enterprise Grid

Impact

hoch

Kontrolle

DLP + Screenshot Policy

Owner

Legal/IT

Frist

2026-06-12

Statusrot

ID

R-03

Risiko

AirTags an LKW erzeugen Beschäftigtendaten ohne BV

Asset

Fuhrpark

Impact

mittel

Kontrolle

Betriebsvereinbarung + Zweckbindung

Owner

HR

Frist

2026-06-30

Status

gelb

ID

R-04

Risiko

Java-Code-Signing-Zertifikat läuft im Juli ab

Asset

Build Pipeline

Impact

hoch

Kontrolle

PKI-Inventar + HSM-Prüfung

Owner

Engineering

Frist

2026-06-10

Status

rot

Tabellenblatt: Nachweise

Nachweis	Akte	Fehlt
Restore-Test	11-backup-restore-protokoll.pdf	vollständiger AD-Recovery-Test
Betriebsrat	15-betriebsrat-mdm-airtags.eml	Beschlussfassung

Nachweis	Akte	Fehlt
Cloud C5	07-slack-cloud-security-memo.pdf	Subprozessorenliste

IT / Legal 26.05.

IT

Wenn wir Slack morgen nicht freigeben, ziehen Vertrieb und Service weiter über private WhatsApp-Gruppen.

Legal

Dann lieber sauber schnell: Datenklassen, externe Gäste, Screenshot-Regel, Betriebsrat, Adminrechte.

IT

AirTags an LKWs hängen schon an acht Fahrzeugen. Logistik sagt Diebstahlschutz.

Legal

Dann muss das in dieselbe Vorlage. Zweckbindung, Beschäftigtendaten, Zugriff, Löschung.

Bilddatei: 12-whatsapp-it-legal.jpg

13-screenshot-siem-alerts.jpg

SOC Alerts

SOC

High: impossible travel admin@lahnwerke

SOC

Medium: expired certificate build-signing-02 in 32
Tagen

SOC

Low: external Slack guest invited to channel
#customer-vpn-log

Bilddatei: 13-screenshot-siem-alerts.jpg

Chronologie der Sicherheits- und Rolloutvorgänge

Lahnwerke Maschinenbau AG · Stand 3. Juni 2026

Datenbasis	SIEM-Screenshot, Restore-Protokoll, E-Mails, Assetliste, Lieferantenfragebogen
Zeitbasis	Mitteeuropäische Sommerzeit; Systemzeiten vor Schlussbewertung abgleichen
Kontrolle	Marlene Seifert, CISO; Lisa Wenstedt, Rechtsanwältin

1. Ereignislinie

Datum und Uhrzeit	Vorgang	Quelle	Noch zu sichern
3. März 2026	Acht Werkzeugcontainer mit AirTags im Servicefuhrpark erfasst	Excel-Assetliste	Seriennummern, Nutzerzugriffe, Ausgabebelege
18. März 2026	Fachbereich beantragt externe Slack-Kanäle für Stahlring und MARSEN	Change-Ticket COL-441	Datenklassen und Gastrollen
22. April 2026	Engineering meldet Ablauf des Code-Signing-Zertifikats zum 9. Juli	PKI-Notiz	Keystore-Standort und Rotationsplan
7. Mai 2026, 03:14 Uhr	Erster auffälliger Login über Frankenturm-VPN	SIEM-Alarm 47118	Quelladresse, Benutzerkonto, Sessioninhalt
7. Mai 2026, 07:42 Uhr	SOC setzt Ticket auf mittlere Priorität	Ticket SOC-2026-188	Begründung der Einstufung und Eskalationsweg
14. Mai 2026, 08:00 Uhr	Wiederanlaufstest beginnt	Restore-Protokoll	Teilnehmer- und Freigabeliste
14. Mai 2026, 14:07 Uhr	Fileserver wiederhergestellt; ERP-Test abgebrochen	Restore-Protokoll	AD-Recovery-Dokumentation und ERP-Abbruchlog
23. Mai 2026, 14:06 Uhr	Frankenturm verlangt dauerhaft offenen VPN-Tunnel ohne Session Recording	E-Mail 10	SLA-Alternative und technische Mindestkonfiguration
24. Mai 2026, 16:22 Uhr	Betriebsrat verlangt Beteiligung bei MDM, AirTags und Logging	E-Mail 15	Bestehender Rolloutumfang und Verfahrensstand
26. Mai 2026, 07:42 Uhr	CISO fordert belastbare Leitungsvorlage	E-Mail 09	Entscheidungsumfang und Budgetrahmen
29. Mai 2026, 08:30 Uhr	Vorstand erteilt vier Prüf- und Beschaffungsaufträge	Sitzungsnotiz, Unterschrift offen	Unterzeichnetes Protokoll
2. Juni 2026, 09:20 Uhr	Cloud-Anbieter übermittelt nur Zusammenfassung des C5-Testats	E-Mail und PDF	Vollständiger Bericht, Scope und Subdienstleister
12. Juni 2026, 08:30 Uhr	Folgesitzung zu Budget und Rolloutfreigaben	Kalendereinladung	Entscheidungsvorlage und Maßnahmenstatus
18. Juni 2026	Geplanter Firmware-Release 4.8	Engineering-Roadmap	Neues Zertifikat und signierter Testbuild

9. Juli 2026	Ablauf des bisherigen Code-Signing-Zertifikats	Zertifikatsinventar	Rotation und Sperrkonzept
--------------	--	---------------------	---------------------------

2. Fristen- und Wiedervorlagen

Kontrollpunkt	Arbeitsdatum	Verantwortlich	Erledigungsnachweis
VPN-Logpaket vollständig	4. Juni 2026	SOC-Leitung	Hashliste, SIEM-Export, Ticketverlauf
Konzern- und Sekordaten bestätigt	5. Juni 2026	Finanzen / Recht	Jahresabschluss, Organigramm, Dienstekatalog
Slack-Konfiguration geprüft	8. Juni 2026	Collaboration-Team	Adminexport und Abnahmeprotokoll
AirTag-Inventar und Rollen	8. Juni 2026	Logistik / IT	Geräteliste und Zugriffsreport
Restore-Nachtest	10. Juni 2026	IT Operations	Messwerte je System und Abbruchprotokoll
Vorstandsvorlage	11. Juni 2026, 12:00 Uhr	CISO / Recht	Version 1.0 mit Quellenanhang
Firmware-Signierung	16. Juni 2026	Engineering	Signierter Testbuild und Rollbackplan

3. Offene Abweichungen

Die Assetliste zählt acht AirTags, die Betriebsratsmail spricht von acht Fahrzeugen. Tatsächlich sollen nach Auskunft der Logistik die Tags an Containern und nicht dauerhaft an Fahrzeugen befestigt sein. Seriennummern und Ausgabeprotokolle entscheiden über die Zuordnung.

Der interne Bericht nennt eine MFA-Abdeckung von 95 Prozent; das technische Exportblatt weist für Service- und Wartungskonten nur 70 Prozent aus. Zähler, Nenner und Ausnahmen sind zu dokumentieren.

Der Dienstleister bezeichnet den VPN-Zugang als für die SLA-Erfüllung erforderlich. Ein konkreter Wartungsauftrag für den Login am 7. Mai liegt bislang nicht vor.

Lisa Wenstedt · Rechtsanwältin · Technische Gegenkontrolle durch Marlene Seifert, CISO

04-vorstandsvorlage-cyber-roadmap.docx

Vorstandsvorlage Cyber-Roadmap

Die Lahnwerke Maschinenbau AG betreibt Produktions-IT, ein europaweites Ersatzteillager, Telematik in 88 LKW und mehrere Cloud-SaaS-Dienste. Die Vorstandsvorlage soll keine bloße Zertifikatsliste werden, sondern die Entscheidung über Budget, Verantwortlichkeit und Nachweise ermöglichen.

Der CISO hält eine NIS-2-Betroffenheit für wahrscheinlich, aber die Sektorzuordnung ist nicht sauber dokumentiert. Einkauf und Logistik möchten Slack und AirTags sofort freigeben; HR verlangt Betriebsratsbeteiligung.

Die kritischsten offenen Punkte sind Lieferanten-Fernwartung, fehlende Restore-Tests, Zertifikatsabläufe in Java-Signierprozessen und unklare Screenshot-Regeln in Supportkanälen.

- BSIG 2025 und NIS-2 live prüfen
- BSI-Grundschutz-Schutzbedarf sauber dokumentieren
- Slack/MDM/AirTags nicht getrennt, sondern als Daten- und Securityverbund betrachten

Policy-Entwurf: Screenshots und Chatkanäle

Screenshots aus Logs, Tickets und Kundenumgebungen dürfen nicht ungeprüft in offene Chatkanäle gestellt werden. Tokens, personenbezogene Daten, Gesundheitsdaten, Kundengeheimnisse und Quellcode werden vor Weitergabe geschwärzt oder in freigegebene Systeme verschoben.

Externe Channels benötigen einen verantwortlichen Owner, Ablaufdatum und Datenklasse.

- Keine privaten Messenger für Kundenstörungen
- Sicherheitsvorfälle nur im Krisenkanal
- Legal Hold wird gesondert angeordnet

Version 0.8 zur Vorstands freigabe

Geltungsbereich und Rollen

Die Richtlinie gilt für die Lahnwerke AG, Werk Nord, Werk Süd und die zentral verwalteten Endgeräte. Verantwortlich sind CISO Dr. Nora Esch, IT-Betrieb Markus Ehlert, Einkauf Nadine Krug und die jeweilige Systemverantwortung. Private Messenger, private Cloudspeicher und nicht inventarisierte Ortungsgeräte dürfen nicht für Betriebsdaten eingesetzt werden.

Vorfälle werden mit Asset, Uhrzeit, Entdecker, technischer Beobachtung, betroffener Funktion und Erstmaßnahme im Register INC-2026 erfasst. Die rechtliche Meldefrist wird nicht aus dem bloßen SIEM-Alarm abgeleitet; technische Bewertung, Kenntnisstand und Freigabezeitpunkt sind getrennt zu protokollieren.

Konkrete Arbeitsregeln

Screenshots aus Slack oder administrativen Konsolen werden als PNG mit Systemzeit, Kanal, Ersteller und unverändertem Original gesichert. Exportierte Nachrichten erhalten einen Prüfsummenvermerk. AirTags und vergleichbare Geräte werden nur nach Inventarisierung, Zweckfestlegung und Beteiligungsprüfung ausgegeben.

Für Fernzugriffe von Lieferanten gelten benannte Konten, Mehrfaktorauthentifizierung, freigegebene Wartungsfenster und Sitzungsprotokolle. Jede Ausnahme benötigt Ticketnummer, Risikoentscheidung, Ablaufdatum und verantwortliche Freigabe. Reviewtermin ist der 16. Juni 2026 um 09:00 Uhr.

Krisenstabs-Runbook — Auszug

Aktivierungstrigger

Der Krisenstab wird aktiviert, sobald **eines** der folgenden Ereignisse eintritt:

- Vermuteter oder bestätigter Einbruch in produktive IT-Systeme (Produktion, Engineering, ERP, M365-Tenant).
- Eingehende Sicherheitswarnung des BSI, eines CERT, eines Versicherers oder eines Geschäftspartners mit konkretem Bezug auf Lahnwerke-Systeme.
- Ungeplanter Ausfall von M365 (Teams/Outlook/SharePoint) länger als 60 Minuten in Verbindung mit ungewöhnlichem Verhalten.
- Verlust eines mit Lahnwerke-Daten konfigurierten Endgeräts (Laptop, Smartphone, AirTag-bewehrte Werkstücke), insbesondere mit Hinweisen auf gezielten Diebstahl.
- Eingehender Hinweis über eine externe Meldestelle (Hinweisgeber, Auditor, Kunde) auf konkrete Datenschutz- oder Cybersicherheitsverletzungen.

Besetzung

Rolle	Hauptperson	Vertretung	Eskalationsbefugnis
Krisenstabsleitung	CEO	COO	volle
Informationssicherheit	CISO	Security-Engineer (Bereitschaft)	technisch
Rechtsabteilung	Justiziarin Dr. Wedekind	Stv. Justitiariat	rechtlich, einschl. Anzeigerstattung
Datenschutz	DSB Frau Brauer (extern)	DSB-Stellvertretung interne IT	DSGVO-Meldung Art. 33
HR / Personal	Personalleitung	Stv. PL	Beschäftigtenkommunikation
Externe Kommunikation	Kommunikationsleitung	Pressesprecher Stahlring AG (Eigentümer)	Pressemitteilungen
IT-Betrieb	Leitung IT-Operations	Bereitschaftsdienst	technische Sofortmaßnahmen
Externer Forensiker	Firma Bittner+Renz, Düsseldorf	Backup: NorthSec, Hamburg	Forensik-Image-Sicherung

Offene Lücken (Stand vor Vorfall)

- **Notfalltelefonliste:** Aktuell nur in SharePoint hinterlegt. Bei M365-Ausfall NICHT verfügbar. Sofortmaßnahme: Liste in verschlüsselter Offline-Kopie (Datentresor, USB) und Papiausdruck im Tresor der Geschäftsleitung; halbjährlicher Test.
- **Out-of-Band-Kommunikation:** Bisher kein Backup-Messenger. Empfehlung: Signal-Gruppe "Lahnwerke-CIRT" mit allen Krisenstabsmitgliedern, parallel SMS-Verteiler.
- **Krisenstabraum:** Bisher kein dedizierter Raum, der vom Hauptnetz abkoppelbar ist. Vorschlag: Besprechungsraum 4-A mit Stand-alone Internetzugang (LTE-Router) als Fallback-Krisenstabraum.
- **Decision-Log:** Bislang ohne strukturierte Vorgabe. Künftig pro Eskalationsstufe Pflichtprotokoll mit Zeitstempel, Beschluss, Begründung, Verantwortlichem.

0-30-Minuten-Checkliste

1. Alarm via Telefon an Krisenstabsleitung (CEO) und CISO; bei Nicht-Erreichbarkeit über Vertretungsliste durchrufen.
2. Erste Einschätzung CISO: betroffene Systeme, geschätzter Datenumfang, externe Sichtbarkeit.

3. Justiziarin entscheidet über sofortige NIS2-Frühwarnung (innerhalb 24 Stunden an BSI nach § 32 BSIG iVm NIS2-Umsetzung) und DSGVO-Meldung (innerhalb 72 Stunden nach Art. 33 DSGVO).
4. IT-Betrieb beginnt Isolierung betroffener Segmente, sichert Logs, hält forensisches Image vor.
5. Externer Forensiker wird informiert und in Bereitschaft gesetzt.
6. Kommunikationsleitung bereitet **Holding-Statement** vor (keine Veröffentlichung ohne Krisenstabsleitung).

30-Minuten-bis-4-Stunden-Checkliste

7. Krisenstab tagt physisch oder per Signal/Telefon — kein M365.
8. Decision-Log starten, Verantwortlichkeiten dokumentieren.
9. Eingehende Anfragen (Kunden, Presse, Beschäftigte) zentral kanalisieren über Kommunikationsleitung.
10. Konkrete NIS2-Frühwarnung an BSI vorbereiten; bei wesentlicher Beeinträchtigung Meldung über das BSI-Meldeportal absetzen (Konto siehe Justizariat).
11. Bei personenbezogenen Daten: Vorabprüfung Art. 33 DSGVO durch DSB; bei "wahrscheinlich Risiko für Rechte und Freiheiten" → Meldung an Landesdatenschutzaufsicht.

4-bis-24-Stunden-Checkliste

12. Erste forensische Erkenntnisse: Eindringvektor, Persistenzmechanismen, betroffene Datenkategorien.
13. NIS2-**Erstmeldung** an BSI ergänzen (sofern noch nicht abgesetzt).
14. Versicherung (Cyber-Police) informieren — Frist je Police prüfen, oft 48 Stunden.
15. Bei betroffenen Geschäftspartnern: vertragliche Informationspflichten (AVV, B2B-Verträge) auswerten.
16. Beschäftigtenkommunikation: kurze, sachliche Mitteilung; Hinweis auf Mitwirkungspflichten und Pressekontakt-Verbot.

24-bis-72-Stunden-Checkliste

17. NIS2-**Folgenotmeldung** mit konkretem Schadensbild.
18. Art. 33 DSGVO Meldung absetzen, sofern Erkenntnisse die Risikoeinschätzung bestätigen.
19. Bei Betroffenen-Risiko nach Art. 34 DSGVO: Benachrichtigung der Betroffenen vorbereiten.
20. Externer Krisenkommunikator (auf Bereitschaft) erstellt Q&A für Presse und Vertrieb.
21. Aufsichtsrat informieren (gemäß § 90 AktG, soweit konzernrechtlich einschlägig — Stahlring AG als Eigentümerin).

Nach Abschluss

- Vollständige Schlussmeldung an BSI gemäß NIS2-Vorgaben.
- Lessons-Learned-Workshop binnen 4 Wochen.
- Anpassung dieses Runbooks; Versionierung mit Datum und Verantwortlichem im Krisenstabsraum.

WORD-DOKUMENT (ORIGINAL-LAYOUT)

18-java-pki-zertifikatsnotiz.docx

Java / PKI — Zertifikatsnotiz und Risikobewertung

Tatsache

Das **Code-Signing-Zertifikat** für die Java-Build-Pipeline der Lahnwerke-Produktfirmware läuft am **09.07.2026** ab. Der Keystore mit dem privaten Schlüssel liegt nach Auskunft des Engineering-Teams aktuell **auf einem CI/CD-Runner-Volume** in einem Azure-DevOps-Pool, eingebunden als Persistent Volume (PV). Der **HSM-Einsatz** (Hardware Security Module) war im IT-Budget 2025 bereits eingeplant, wurde aber nie beauftragt — die Beschaffung scheiterte mehrfach an der Klärung der Verantwortlichkeit zwischen IT und Produktentwicklung. Der **Release 4.8** der Produktfirmware (geplant für 18.06.2026) hängt direkt am Zertifikat: Ohne gültige Signatur akzeptieren weder Engineering-Hosts noch Kundenanlagen die neue Firmware.

Identifizierte Risiken

1. Ablaufrisiko Zertifikat (Compliance / Operations)

- Ohne rechtzeitige Erneuerung **wird Release 4.8 nicht ausgespielt werden können**.
- Bei Lieferverzug an Kunden mit vertraglich vereinbartem Release-Datum: Vertragsstrafenrisiko nach VOB-/Werk-/Liefervertragsklauseln; betroffen sind insbesondere die Kunden "Stahling AG" (interner Konzernkunde) und "MARSEN GmbH" (Verzug-Pönale 5.000 EUR/Werktag).
- Bei nicht-signierten Notfall-Hotfixes: Eskalation in Kundeneinsatz.

2. Keystore-Lokalisierung (IT-Sicherheit)

- Der **Keystore auf einem Runner-Volume** widerspricht den allgemeinen Empfehlungen des BSI (BSI TR-03145) und der NIST SP 800-57. Korrekte Aufbewahrung wäre in einem HSM oder mindestens in einem dedizierten Vault mit Hardware-Bindung.
- Bei Kompromittierung des Runner-Volumes (etwa durch Diebstahl der CI-Pipeline-Credentials, kompromittierte Build-Skripte oder Insider-Zugriffe) wäre der private Schlüssel exfiltrierbar.
- Anschließende Schadenswirkung: Angreifer könnte beliebige Firmware signieren und in die Lahnwerke-Produktbasis einspeisen — **Lieferkettenangriff-Szenario** (z. B. SolarWinds-Typ).
- Diese Risikolage ist im Sinne der NIS2-Richtlinie (Art. 21 NIS2 iVm § 30 BSIG) ein "Cybersicherheitsrisiko, das angemessenes Risikomanagement erfordert" und unterliegt der Verantwortung der Geschäftsleitung.

3. Versäumte HSM-Beschaffung (Compliance Governance)

- HSM war 2025 budgetiert (intern Position "IT-Hardware 2025-IT-077"), wurde aber nie beschafft.
- Verantwortlich für die nicht-Beschaffung: ungeklärte Schnittstelle zwischen IT-Operations und Produktentwicklung; faktisch niemand.
- Geschäftsleitung muss **dokumentieren**, warum die Risikoreduzierungsmaßnahme nicht umgesetzt wurde, und welche kompensierenden Maßnahmen ergriffen wurden. Bei späterem Sicherheitsvorfall ist diese Dokumentation für die Frage der Geschäftsleiterhaftung (§ 91 Abs. 2 AktG; § 43 GmbHG) und Compliance-Pflicht entscheidend.

Sofortmaßnahmen (heute)

Operations (24-48 Stunden)

1. **Beschaffung eines Cloud-HSM** (z. B. Azure Key Vault Premium mit FIPS-140-2 Level 2 HSM, oder AWS CloudHSM) — schnellste Option, ohne Wartezeit auf physisches HSM.

2. **Schlüsselrotation:** Neuen Schlüssel im HSM erzeugen, neues Zertifikat bei der CA beantragen, alte Build-Pipeline auf neuen Schlüssel umstellen.
3. **Runner-Volume bereinigen:** privaten Schlüssel löschen, Audit-Log sichern.

Compliance (1 Woche)

4. **Risikoregister-Eintrag:** aktuelles Risiko vollständig dokumentieren mit Schadenshöhe, Eintrittswahrscheinlichkeit, Mitigationsstatus.
5. **Geschäftsleitungs-Information:** Memo mit Risiko, Maßnahme, Restrisiko zur Kenntnisnahme.
6. **NIS2-Pflichtenprüfung:** Klären, ob das vorhandene Risiko ein "wesentlicher Sicherheitsvorfall" iSv § 32 BSIG (Umsetzung NIS2) wäre und ob Meldepflicht besteht. **Vorab:** derzeit kein Sicherheitsvorfall, sondern erkanntes Risiko — keine Meldepflicht; aber Dokumentationspflicht.

Strategie (4 Wochen)

7. **Physisches HSM** beschaffen für langfristigen Einsatz (Nitrokey HSM oder Yubico YubiHSM; alternativ Thales nShield für Enterprise).
8. **Verantwortlichkeits-Matrix** zwischen IT-Ops und Produktentwicklung neu definieren — wer ist für CI/CD-Sicherheit ressortverantwortlich.
9. **Audit der gesamten CI/CD-Pipeline:** weitere Geheimnisse (Secrets, Tokens, Zertifikate) lokalisieren und in den Vault verlagern.

NIS2-Relevanz

- **Art. 21 NIS2** (Maßnahmen für Cybersecurity-Risikomanagement): Kryptografie, Zugangskontrolle, Lieferkettenschutz sind Pflichtmaßnahmen.
- **Geschäftsleitungs-Pflichten** Art. 20 NIS2 (in deutscher Umsetzung § 35 BSIG): Geschäftsleitung muss "die getroffenen Maßnahmen genehmigen, deren Umsetzung beaufsichtigen und kann persönlich haftbar werden, wenn sie ihre Pflichten verletzt".
- Bei einem späteren Vorfall, der auf den hier dokumentierten Mangel zurückgeht, wäre die Frage zu beantworten: warum wurde das Risiko nicht behoben?

Verantwortlichkeiten

- **CISO:** heute Risikoregister aktualisieren, Cloud-HSM-Beschaffung anstoßen.
- **IT-Operations:** Schlüsselrotation operationell vorbereiten.
- **Geschäftsleitung:** Memo bis 06.06.2026 zur Kenntnisnahme; Freigabe Beschaffung.
- **Externe Beratung:** Spezialfrage Schlüsselverwaltung in CI/CD-Pipelines an Beratung Klein+Steinberg (vorgesehen).

21-offene-punkte-und-lueckenliste.docx

Offene Punkte und Lückenliste — NIS2-Cybersicherheit Lahnwerke

Status

Stand: 02.06.2026. Mandant: Lahnwerke AG (Industrieprodukte, Konzerntochter Stahlring AG). Beratung: Dr. Henning Brettschneider (IT-/Cybersecurityrecht), Senior Associate L. Wenstedt.

Offene Punkte

1. Rechtsquellenprüfung

- BSIG in der Fassung des NIS2-Umsetzungsgesetzes 2024/2025; insbesondere die Paragraphen 28-37 BSIG (Risikomanagement, Meldepflicht, Geschäftsleitungspflichten). Live gegen [gesetze-im-internet.de](https://www.gesetze-im-internet.de) verifizieren.
- **NIS2-Richtlinie 2022/2555**: aktueller Stand der nationalen Umsetzung in den Mitgliedstaaten relevant, weil Lahnwerke auch in Österreich, Polen, Tschechien aktiv ist.
- **DSGVO Art. 32-34**: technische und organisatorische Maßnahmen, Meldepflichten, Benachrichtigung Betroffener.
- **Cyber Resilience Act (EU 2024/2847)**: relevant für die Frage, ob Lahnwerke-Produkte unter die Vorgaben fallen — Übergangsfrist beachten.
- **DigitalEU-VO 2018/1807**: freier Datenverkehr nicht-personenbezogener Daten — relevant für Cloud-Setup-Frage.

2. Fehlende technische und kaufmännische Nachweise

- **Vollständiges Asset-Inventar**: Aktuelles Asset-Inventar liegt mit Stand 03/2025 vor. Müsste auf den Stand 06/2026 aktualisiert werden — insbesondere zu OT-Komponenten (Sensorik, Steuerungen).
- **Lieferketten-Inventar**: Welche Drittanbieter haben Zugriff auf Lahnwerke-Systeme? Vollständige Liste der SaaS-Anbieter (Slack, M365, Teams-Telefonie, Salesforce, AzureDevOps), Cloud-Provider, externe Wartungsfirmen.
- **Patch-Management-Berichte** der letzten 12 Monate.
- **Notfallübungs-Protokolle** der letzten 24 Monate (existieren in welchem Umfang?).
- **Schulungsnachweise** für Beschäftigte zu Phishing und Cybersecurity.
- **AVV-Verträge mit Drittanbietern**: vollständig? Aktualität?
- **Verträge mit dem externen Forensiker** (Bittner+Renz, NorthSec): SLA, Bereitschaftsstufen, Tagessätze.

3. Widersprüche und Inkonsistenzen

- **Slack-Nutzung vs. interne Richtlinie**: Lahnwerke-IT-Richtlinie 2024 verbietet die Nutzung externer Messenger für vertrauliche Kommunikation. Tatsächlich nutzen Engineering und Vertrieb Slack intensiv. Diskrepanz zwischen Richtlinie und Praxis dokumentieren.
- **AirTag-Verwendung an Werkstücken**: Aktenstück 14 dokumentiert, dass Lahnwerke AirTags zur Verfolgung von Werkstücken (Lieferung an Kunden) verwendet. Datenschutzrechtliche Bewertung (Datenfluss an Apple, personenbeziehbarer Standort) ist nicht dokumentiert.
- **MFA-Coverage**: Behauptung im internen Report 04/2026: "MFA bei 95 % aller Accounts aktiv". Tatsächlich: nur 70 %, weil mehrere Service-Accounts und Wartungs-Accounts ausgenommen. Lücke schließen.

4. Beweisfundstellen für harte Aussagen

- Behauptung "Lahnwerke ist NIS2-pflichtig": derzeit nur Vermutung über Größenklassifizierung. Bessere Belege: Jahresabschluss Beschäftigtenzahl, Konzernzuordnung, Sektorzuordnung nach Anhang I/II der Richtlinie.

- Behauptung "kein wesentlicher Vorfall seit 2023": derzeit auf interne Vorfalls-Logs gestützt; vollständige Aufstellung mit Klassifikation nach NIS2-Wesentlichkeitskriterien anfertigen.
- Behauptung "Geschäftsleitung ist über Cybersecurity-Lage informiert": derzeit nur indirekt aus Aufsichtsratsprotokollen. Bessere Belege: konkrete Sitzungsprotokolle Geschäftsleitung mit ausdrücklicher Cybersecurity-Berichterstattung.

Lückenliste (Dokumente)

Lücke	Beweisthema	Beschaffungsweg	Frist	Verantwortlich	Status
Aktualisiertes Asset-Inventar	NIS2 Paragraf 30 BSIG	intern IT	4 Wochen	CISO	offen
Lieferketten-Inventar	NIS2 Paragraf 30 BSIG	intern Einkauf + IT	3 Wochen	Einkauf	offen
Patch-Management-Berichte 06/2025-06/2026	Sorgfalt	intern IT	1 Woche	IT-Operations	beauftragt
Notfallübungs-Protokolle	NIS2 Risikomanagement	intern CISO	2 Wochen	CISO	offen
Schulungsnachweise Cybersecurity	NIS2 Schulungspflicht	HR	1 Woche	HR	beauftragt
AVV-Verträge alle SaaS-Anbieter	DSGVO Art. 28	Justizariat	2 Wochen	Justizariat	initialisiert
Forensiker-SLA	Bereitschaft Vorfall	Justizariat	1 Woche	Justizariat	gemacht
Cloud-HSM-Beschaffung Code-Signing	siehe Aktenstück 18	IT-Operations	5 Werktage	CISO	beauftragt
Datenschutzbewertung AirTag-Nutzung	DSGVO + Paragraf 4f BDSG	DSB	2 Wochen	DSB	initialisiert
Slack-Nutzungsbewertung	Geschäftsgeheimnisse + DSGVO	DSB + Justizariat	2 Wochen	DSB	initialisiert
Notfalltelefonliste offline	siehe Aktenstück 16	Sekretariat	5 Werktage	Sekretariat	beauftragt
MFA-Coverage 100 %	Sorgfalt Paragraf 30 BSIG	IT-Operations	3 Wochen	IT-Operations	offen

Grundregeln für die Aktenbearbeitung

- Originalquellen und aktuelle Gesetzesfassungen an aktueller amtlicher Quelle prüfen — nicht aus älteren Schriftsätzen übernehmen.
- Fehlende technische oder kaufmännische Nachweise nicht durch Vermutungen ersetzen — als Lücke führen, gezielt schließen.
- Widersprüche zwischen Richtlinie, Tatsache und Vertrag explizit benennen — Risiko der unredlichen Compliance-Behauptung.
- Für jede harte Aussage Aktenfundstelle nennen — andernfalls "noch zu belegen" markieren.
- Geschäftsleitungs-Information dokumentieren, damit Paragraf 30 BSIG / Art. 20 NIS2-Pflichten nachweisbar sind.

Nächste Aktualisierung

Donnerstag, 04.06.2026, 14:00 Uhr — vor der Geschäftsleitungssitzung.

Abgleich Unternehmensdaten

Verbindlicher Aktenkopf

Mandantin ist die Lahnwerke AG, Rheinuferstraße 88, 56068 Koblenz, eingetragen beim Amtsgericht Koblenz unter HRB 18422. Die Bezeichnung als GmbH in einem frühen Gesprächsvermerk beruhte auf einer übernommenen Lieferantenvorlage und wird für weitere Arbeitsprodukte nicht verwendet.

Für jede offene Position werden Eigentümer, Lieferdatum, technische Quelle und Freigabeperson eingetragen. Fehlende C5-Unterlagen, Wiederanlaufprotokolle und Lieferantenantworten werden nicht als erfüllt markiert, nur weil ein Link oder eine Selbstauskunft vorliegt.

Beschlussfelder Cyber- und Betriebsstabilität

Vorstandssitzung am 12. Juni 2026

Vorlage	Marlene Seifert, CISO; Dr. Clara Lehnert, Leitung Recht
Stand	4. Juni 2026, 19:05 Uhr
Budgetrahmen	Bis 280000 EUR für Sofortmaßnahmen; Jahresprogramm gesondert
Anlagen	Risikoregister, Restore-Protokoll, Lieferantenfragebogen, PKI-Notiz, Betriebsratsmail

1. Beschlussbedarf

Beschlussfeld	Variante A	Variante B	Fehlender Nachweis
Lieferantenfernzugriff	Zeitlich begrenzter Zugang je Ticket mit MFA und Aufzeichnung	Dauerzugang nur in isoliertem Wartungsnetz	Technisches Konzept und SLA-Angebot
Slack	Externe Kanäle nur für zwei Pilotkunden	Rollout bis Abschluss der Kontrollen zurückstellen	Adminexport, Datenklassen und Exit-Prozess
Ortung und Geräteverwaltung	Weiterbetrieb im bisherigen Umfang mit Zugriffsbeschränkung	Vorübergehende Deaktivierung neuer Geräte	Inventar, Zweck, Rollen und Beteiligungsstand
Wiederanlauf	Vollständiger Nachttest binnen sieben Tagen	Externe Übung mit Forensik und Fachbereichen	Testplan, Systeme und Abnahmekriterien
Code Signing	Cloud-HSM als Sofortlösung	Physisches HSM mit Übergangszertifikat	Angebote, Migrations- und Rollbackplan

2. Tatsachenstand

Der Login vom 7. Mai ist als auffälliges Ereignis dokumentiert. Ob ein unbefugter Zugriff oder Datenabfluss vorlag, ist noch offen. Der ERP-Wiederanlauf wurde nicht erfolgreich abgeschlossen. Acht Ortungsgeräte sind in der Assetliste verzeichnet; ihre Zuordnung zu Containern oder Fahrzeugen ist noch zu bereinigen.

Für die Betroffenheits- und Pflichtenprüfung liegen Konzern- und Dienstedaten noch nicht vollständig vor. Die Vorlage trennt daher technische Sofortmaßnahmen von der abschließenden rechtlichen Einordnung.

3. Beschlussprotokoll

Für jedes Beschlussfeld hält das Protokoll die gewählte Variante oder den abweichenden Wortlaut, den verantwortlichen Vorstand, den operativen Owner samt Vertretung, Termin und Abnahmetermin, den Erledigungsnachweis sowie das konkret verbleibende technische oder betriebliche Restrisiko fest.

Marlene Seifert · Chief Information Security Officer

Telefonvermerk

Brennecke Wenstedt Rechtsanwälte, Düsseldorf. Aufgenommen von Rechtsanwältin Lisa Wenstedt am 05.06.2026, 15:10 Uhr. Telefonkonferenz mit Herrn K. Rehbaum, Frankenturm Automation GmbH, Servicecenter, und Frau Marlene Seifert, CISO der Lahnwerke Maschinenbau AG. Dauer etwa 25 Minuten. Betrifft den VPN-Zugriff vom 7. Mai 2026 auf die Pressenlinie P2.

1 Angaben Rehbaum

Herr Rehbaum erklärt, der Login am 7. Mai um 03:18 Uhr sei eine "proaktive Zustandskontrolle" nach einer Störmeldung der Pressensteuerung gewesen. Auf Nachfrage kann er weder eine Störmeldung noch einen Wartungsauftrag benennen; das Ticketsystem seines Hauses sei "in dem Zeitraum umgestellt worden". Den Namen des Technikers will er erst nach interner Rücksprache nennen; es sei "wahrscheinlich die Nachtschicht in Bamberg" gewesen. Eine Sitzungsaufzeichnung existiert nach seiner Aussage nicht, der Standardvertrag sehe eine solche nicht vor. Den Zugriff auf die Dateiablage ENG-SHARE um 03:19 Uhr erklärt er zunächst mit einem "Ablageordner für Maschinendokumentation"; Frau Seifert hält entgegen, dass der Ordner Konstruktionsdaten enthält und im Berechtigungskonzept für das Servicekonto nicht freigegeben ist. Herr Rehbaum sagt Prüfung zu.

2 Angaben Seifert

Frau Seifert teilt mit, dass das Servicekonto svc-frankenturm seit dem 23. Mai hinter der MFA-Umstellung liegt und seither nur begleitete Zugriffe erfolgt sind, zuletzt am 30. Mai mit Ticket WART-2026-0561. Der Export des VPN-Logs für April und Mai liegt der Kanzlei vor. Für den Login vom 29. April um 22:47 Uhr gibt es ebenfalls kein Ticket; dieser Vorgang war Herrn Rehbaum nach seiner Aussage bislang nicht bekannt.

3 Ergebnis

Herr Rehbaum liefert bis 12.06.2026 schriftlich: Name und Schichtplan des Technikers, Störmeldungs- oder Auftragsnachweis für den 7. Mai, Stellungnahme zum Zugriff auf ENG-SHARE und zum Login vom 29. April. Frau Seifert lässt die Zugriffsrechte des Servicekontos auf ENG-SHARE bis dahin entziehen und sichert die Protokolle. Wiedervorlage 15.06.2026.

Wenstedt

06-nis2-betroffenheitsvermerk.pdf

Vorläufiger Betroffenheitsvermerk

Die Gesellschaft liefert Ersatzteile an Energie- und Verkehrskunden, betreibt aber zugleich eigene digitale Dienste für Fernwartung. Die Einordnung hängt davon ab, welche Dienste tatsächlich am Markt erbracht werden und welche Konzernschwellen erreicht sind.

Nicht ausreichend ist die Aussage, man sei ISO-zertifiziert. Entscheidend ist, welche Pflichten nach NIS-2/BSIG ausgelöst werden, wer registriert, wer meldet und welche technischen Maßnahmen tatsächlich getestet sind.

Punkt	Sachstand	Risiko
Sektor	Produktion plus digitale Fernwartung	Einordnung offen
Größe	ca. 780 MA Konzernverbund	Schwelle wahrscheinlich
Meldung	Incidentprozess nicht getestet	rot

07-slack-cloud-security-memo.pdf

Slack-Rollout: Security- und Legal-Prüfung

Fachbereiche möchten Slack mit externen Channels für Großkunden nutzen. Die Richtlinie muss regeln, welche Datenklassen dort erscheinen dürfen, wie Screenshots behandelt werden und wer externe Gäste freigibt.

Technisch fehlen noch DLP-Regeln, Aufbewahrungskonzept, Admin-Rollen, Exportprozess und Abgleich mit Betriebsrat und Datenschutz.

Thema	Entscheidung
Externe Gäste	nur mit Owner und Ablaufdatum
Screenshots	keine Tokens, keine Personaldaten, keine ungeprüften Logs
Retention	Legal Hold mit DSGVO-Abwägung

11-backup-restore-protokoll.pdf

Restore-Test 14.05.2026

Der Restore des Fileservers gelang nach 6 Stunden. Der ERP-Test wurde abgebrochen, weil die AD-Recovery-Dokumentation nicht auffindbar war. Der Dienstleister hat zugesagt, eine zweite Übung vorzuschlagen.

Die Geschäftsleitung soll nicht nur Backup-Erfolg melden, sondern offen dokumentieren, dass ein vollständiger Wiederanlauf noch nicht bewiesen ist.

System	Ergebnis	Lücke
Fileserver	OK	RPO 12h
ERP	abgebrochen	AD-Recovery fehlt
Telefonie	nicht getestet	Fallback unklar

17-cloud-provider-c5-luecken.pdf

Cloud-Provider-Prüfung

Der Provider verweist auf ein C5-Testat, liefert aber nur eine Zusammenfassung. Die Subdienstleisterliste enthält Supportzugriffe aus mehreren Regionen. Der Exit-Test wurde noch nie durchgeführt.

Für die Vorstandsvorlage ist zu trennen: Vertraglich zugesagt, technisch implementiert, auditiert, ungeprüft.

Kontrolle	Nachweis	Bewertung
C5	Executive Summary	gelb
Subprozessoren	Liste 2025	gelb
Exit	kein Test	rot

PDF-ANHANG (ORIGINALDOKUMENT)

20-board-briefing-draft.pdf

Board-Briefing Arbeitsstand

Die Gesellschaft sollte den Rollout nicht stoppen, aber an rote Mindestbedingungen knüpfen: externe Slack-Channels nur mit Owner, AirTag-Zugriff nur für Logistik-Leitung und Betriebsvereinbarung, Fernwartung nur mit MFA und Session Recording, Restore-Test binnen vier Wochen.

Nächster Beschluss: Budget für PKI/HSM, SOC Use Cases und Lieferantenkontrolle freigeben.

Beschluss	Frist	Owner
Slack Controlled Rollout	14 Tage	CISO
AirTag BV	30 Tage	HR
Restore-Test	4 Wochen	IT Betrieb

24-arbeitsstand-fuer-besprechung.pdf

Arbeitskonferenz Lahnwerke · 5. Juni 2026

Beginn	09:00 Uhr, Werk Wetzlar, Raum W-3.14
Teilnehmer	CISO, Recht, IT Operations, SOC, Engineering, Logistik, Einkauf
Ziel	Quellenfähiger Maßnahmenstand für den Vorstand am 12. Juni
Nicht Gegenstand	Abschließende Zuschreibung des VPN-Ereignisses ohne Forensik

1. Arbeitsstand je Strang

Strang	Gesicherter Stand	Offene Tatsache	Benötigtes Arbeitsprodukt
VPN	Login und Ticket sind dokumentiert	Auftrag, Sessioninhalt und Reichweite	Ereignislinie mit Logfundstellen
Slack	Pilotwunsch und Policy-Entwurf liegen vor	Konfiguration, Gastrollen, Export und Löschung	Freigabeblatt je Kontrollpunkt
AirTags / MDM	Acht Geräte und Betriebsratsanfrage	Objektzuordnung, Zugriff, Zweck und Speicherdauer	Geräte- und Rollenregister
Restore	Fileserver nach sechs Stunden verfügbar	ERP und Active Directory nicht abgenommen	Nachtestprotokoll mit RPO und RTO
PKI	Zertifikat läuft am 9. Juli ab	Schlüsselstandort und Migrationsweg	Entscheidungsvorlage mit Rollback
Lieferkette	Fragebogen enthält rote Lücken	Session Recording, Meldung und Subunternehmer	Nachforderung an Frankenturm

2. Quellenkontrolle

Aussage	Derzeitige Quelle	Kontrolle vor Verwendung
MFA-Abdeckung 95 Prozent	Management-Report April	Rohdatenexport einschließlich Servicekonten
Keine Datenabflüsse	Mündliche SOC-Auskunft	DLP-, Proxy-, EDR- und VPN-Logs
AirTags nur an Containern	Auskunft Logistik	Seriennummern und Ausgabeprotokoll
C5-Nachweis vollständig	Executive Summary	Scope, Zeitraum, Abweichungen und Subdienstleister
Restore erfolgreich	Kurzmeldung IT	Systembezogene Messwerte und Fachbereichsabnahme

3. Entscheidungen für die Konferenz

Die Runde legt fest, welche Systeme sofort isoliert oder weiterbetrieben werden, welche Rollouts eine Freigabestufe benötigen, welche Nachweise bis zum Vorstandstermin beschafft werden und welche Aussage wegen offener Tatsachen ausdrücklich nicht in die Vorlage aufgenommen wird.

4. Abschlussblatt

Jeder Maßnahmenpunkt erhält Ticketnummer, verantwortliche Person, Abnahmekriterium, Termin und Fundstelle. Mündliche Zusagen werden noch am selben Tag als Gesprächsnotiz bestätigt. Die Vorstandsvorlage enthält keine unbelegte Prozentangabe und keine pauschale Zertifikatsbehauptung.